

PIA

- Analyse du PIA et évaluation
- Cartographie et registre
- Etude de l'utilisation
- Traitement des risques
- Sécurité et sureté informatique

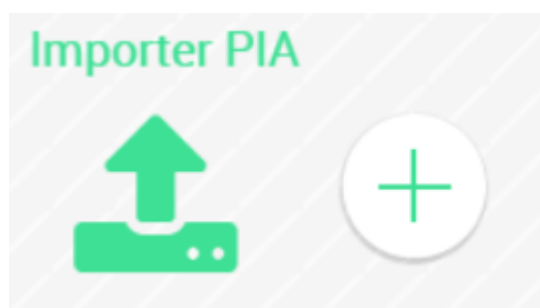
Introduction

Ce travail pratique avait pour objectif d'étudier la manière dont une entreprise peut évaluer et sécuriser ses traitements de données personnelles, tout en respectant la réglementation du RGPD.

À l'aide de l'outil PIA (Privacy Impact Assessment) développé par la CNIL, nous avons appris à identifier les risques liés à la gestion des données, à évaluer leur gravité et leur probabilité, puis à proposer des mesures correctrices adaptées.

1. Analyse du PIA et évaluation des risques

Après l'importation d'un projet



En cours



PIA

(IMPORT) PIA TESTOP

Saisie

Luc, FRET

Évaluation

Pierre, GROSPIRE

Validation

Pierre, GROSPIRE

Catégorie

Catégorie

Date

15/09/2019

Statut

En cours

30%

Éditer

d'exemple dans l'application PIA, nous avons analysé trois types de risques principaux :

Accès illégitime à des données :

Ce risque est considéré comme très grave et fréquent. Il peut entraîner une atteinte à la vie privée et la divulgation d'informations confidentielles.

Exemples de causes : piratage, vol d'identifiants, interception de données.

Modification non désirée des données :

Ce risque est important mais moins fréquent. Une altération involontaire ou malveillante des données peut fausser les informations ou perturber l'organisation.

Exemples : erreur humaine, altération d'un fichier, vol d'accès utilisateur.

Disparition de données :

Ce risque peut être grave, notamment en l'absence de sauvegarde. La perte de données personnelles peut causer une interruption d'activité ou la perte de dossiers essentiels.

Exemples : panne matérielle, suppression accidentelle, cyberattaque.

Mesures correctrices mises en place :

Sauvegardes automatiques et redondantes,
Chiffrement des bases de données,
Authentification forte des utilisateurs,
Journalisation et contrôle des accès.

Ces actions permettent de réduire significativement la probabilité et la gravité des incidents, même si les risques ne disparaissent jamais totalement.

2. Cartographie et registre des traitements

La cartographie des traitements de données personnelles est une étape clé dans la conformité RGPD. Elle consiste à recenser tous les traitements effectués dans une organisation afin de savoir :

quelles données sont collectées,
par qui elles sont utilisées,
et dans quel but.

Cette cartographie repose sur un document préalable appelé registre des traitements, qui regroupe de manière détaillée les opérations de collecte, de stockage, d'utilisation et de conservation.

L'un ne peut exister sans l'autre : le registre constitue la base d'un suivi précis et la cartographie permet d'identifier visuellement les risques associés à chaque flux de données.

3. Étude de l'utilisation des données (exemple Castorama.fr)

Lorsqu'un utilisateur saisit des informations personnelles sur le site Castorama.fr (nom, adresse e-mail, historique d'achats, etc.), ces données peuvent être :

utilisées pour gérer son compte client,

partagées avec d'autres enseignes du groupe Kingfisher,

transmises à des partenaires ou à des assureurs,

exploitées à des fins marketing ou statistiques.

Cependant, le texte d'information du site ne précise pas les mesures techniques de sécurité (comme le chiffrement ou les restrictions d'accès).

Il est donc impossible d'affirmer que la confidentialité des données est pleinement assurée, même si le partage se fait entre partenaires autorisés.

4. Traitement et risques liés aux données personnelles

Le cycle de vie d'une donnée personnelle suit plusieurs étapes :

Collecte : par formulaires en ligne, applications, cookies, cartes de fidélité, vidéosurveillance, etc.

Risque : collecte excessive ou sans consentement.

Stockage : sur des serveurs internes, bases de données ou solutions cloud.

Risque : perte, vol ou piratage.

Analyse et diffusion : à des fins de marketing, de statistiques ou de communication commerciale.

Risque : mauvaise utilisation, revente ou fuite d'informations.

Suppression ou anonymisation : lorsque les données ne sont plus nécessaires.

Risque : conservation trop longue ou suppression incomplète.

Obligations principales du RGPD :

Collecter uniquement les données nécessaires,

Obtenir le consentement clair des personnes concernées,

Garantir la confidentialité, l'intégrité et la disponibilité des informations,

Supprimer les données après utilisation,

Permettre à l'utilisateur de consulter, rectifier ou supprimer ses données.

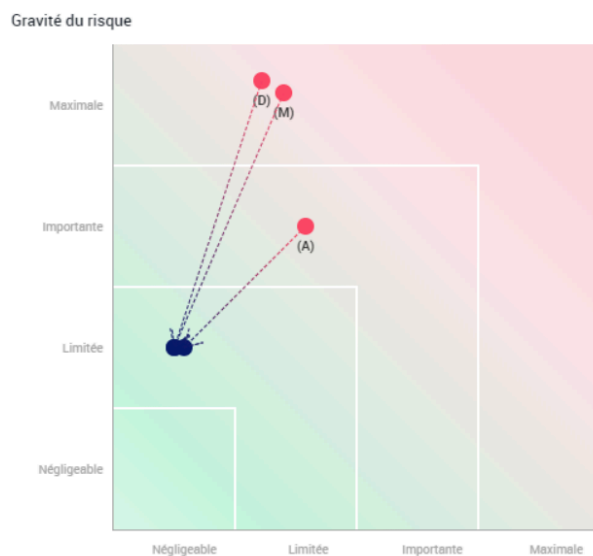
Le non-respect de ces obligations peut entraîner des amendes allant jusqu'à 4 % du chiffre d'affaires mondial ou 20 millions d'euros, ainsi qu'une perte de confiance du public.

5. Sécurité et sûreté informatique

Il est important de distinguer la sécurité (risques intentionnels) et la sûreté (risques accidentels).

Exemple de situation	Type de menace	Explication
Inondation d'un local serveur	Sûreté	Incident naturel, non intentionnel.
Attaque par ransomware	Sécurité	Acte malveillant et délibéré.
Modification du site par un pirate	Sécurité	Intrusion volontaire dans le système.
Panne due à une surcharge électrique	Sûreté	Incident matériel sans intention humaine.

Voici le schéma de fin



Conclusion

Ce travail pratique m'a permis de mieux comprendre le rôle essentiel du PIA dans la protection des données personnelles et la conformité au RGPD. J'ai découvert comment identifier les différents types de risques, évaluer leur gravité et leur probabilité, et mettre en place des mesures de sécurité adaptées pour limiter les menaces.